

Programa del curso

Propósito

Convertir THM Fieldbook, un playbook de consulta rápida, en una asignatura práctica para aprender a razonar sobre pentesting autorizado. El objetivo no es memorizar cadenas: es reconocer entradas, transformaciones, parsers y sinks; formular una hipótesis; construir una prueba mínima; interpretar evidencia; y adaptar la prueba cuando cambia el contexto.

Alcance ético

Todos los comandos, payloads y casos se limitan a laboratorios propios, TryHackMe, CTF y evaluaciones con autorización expresa. El curso no sustituye las reglas de alcance. Una técnica disponible no implica permiso para usarla.

Conocimientos previos

- Navegar por archivos y ejecutar comandos sencillos.
- Entender qué son cliente, servidor, proceso y red.
- Leer inglés técnico básico para consultar manuales.
- Disponer de un laboratorio aislado y autorizado.

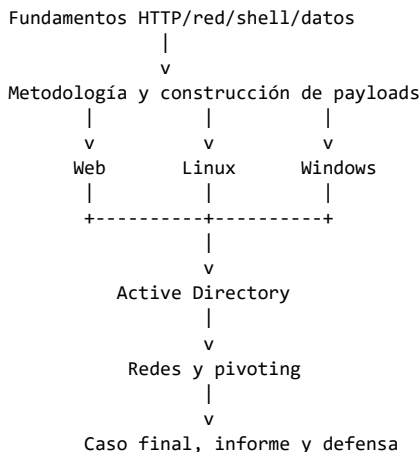
Quien no cumpla estos puntos debe completar las semanas 1 y 2 antes de usar las chuletas operativas.

Objetivos generales

Al finalizar, el estudiante podrá:

1. Explicar el flujo de datos desde una entrada hasta un componente sensible.
2. Enumerar una superficie de ataque basándose en evidencia.
3. Diferenciar indicio, confirmación, explotación e impacto.
4. Construir y descomponer payloads básicos.
5. Diagnosticar fallos de sintaxis, contexto, transporte, filtro y evidencia.
6. Ejecutar una metodología reproducible en web, Linux, Windows, AD y redes.
7. Documentar hallazgos con prueba, resultado, impacto y mitigación.
8. Usar el playbook como consulta sin convertirlo en sustituto del razonamiento.

Dependencias



Carga estimada

- 14 semanas.
- 6 a 8 horas por semana.
- Total orientativo: 90 horas.
- Distribución: 35 % teoría, 45 % laboratorio, 10 % ejercicios y 10 % evaluación/reporting.

Planificación

Semana	Bloque	Teoría	Práctica	Evaluación o criterio de avance
1	Fundamentos I	HTTP, URL, DNS, IP, puertos	Capturar y anotar peticiones	Explicar cada parte de una petición y su destino
2	Fundamentos II	Sesiones, formatos, encoding, shell, permisos, SQL	Transformar entradas sin atacar	Predecir qué parser recibe cada valor
3	Metodología	Evidencia, superficie, hipótesis, prueba mínima	Construir mapa de ataque	Separar observación de conclusión
4	Payloads	Contexto, cierre, quoting, separadores, normalización	Adaptaciones controladas	Justificar cada carácter del payload
5	Web I	Discovery, vhosts, auth, sesiones, acceso	Burp Repeater y comparación	Confirmar sin depender de automatización
6	Web II	SQLi, command/argument injection, SSTI	Pruebas incrementales	Distinguir error de sintaxis y falso positivo
7	Web III	Traversal/LFI, upload, SSRF, XXE, XSS, JWT/API	Caso encadenado	Explicar frontera de confianza e impacto
8	Linux	Enumeración, sudo, SUID, cron, PATH, capabilities	Escalada en laboratorio	Elegir vector por evidencia y riesgo
9	Windows	Servicios, registro, tareas, tokens, DLL, UAC	Enumeración y escalada	Relacionar permiso débil con ejecución
10	AD I	Dominio, LDAP, SMB, Kerberos, NTLM	Enumeración de dominio	Construir mapa de identidades y relaciones
11	AD II	Roasting, PTH/PTT, BloodHound, AD CS, ACL/trusts	Ruta de ataque controlada	Demostrar prerequisites de cada técnica
12	Redes	Pivoting, túneles, rutas, relay y diagnóstico	Acceso a segmento interno	Explicar flujo de ida y vuelta
13	Integración	CVE, transferencia, post-explotación, cierre	Simulacro tipo TryHackMe	Mantener registro de hipótesis y evidencia
14	Evaluación	Repaso y mitigaciones	Examen final e informe	70 % global y ningún bloque crítico bajo 50 %

Bloques y productos

Bloque A: fundamentos

Producto: diagramas de flujo de datos y análisis de peticiones. No se avanza si el estudiante confunde encoding con cifrado, shell con proceso o validación textual con interpretación semántica.

Bloque B: metodología y payloads

Producto: cuaderno de hipótesis con pruebas mínimas. Se exige explicar contexto, parser, sink, evidencia y condición de descarte.

Bloque C: técnicas

Producto: laboratorios web, Linux, Windows y AD. Cada técnica usa la secuencia identificar, confirmar, adaptar, escalar y mitigar.

Bloque D: integración

Producto: caso desconocido, notas cronológicas e informe. Se valora más una conclusión bien demostrada que una lista amplia de pruebas aleatorias.

Prácticas

- Lectura y modificación controlada de peticiones con Burp Repeater.
- Enumeración reproducible con salida guardada.
- Análisis de pequeños fragmentos de código vulnerable.
- Construcción incremental de payloads en servicios locales.
- Escalada de privilegios en máquinas desechables.
- Pivoting entre redes de laboratorio.
- Redacción de hallazgos con evidencia y mitigación.

Cada práctica debe registrar:

Observación	Hipótesis	Prueba mínima	Resultado esperado	Resultado obtenido	Conclusión

Evaluaciones

- Cuestionarios de fundamentos al final de semanas 2 y 4.
- Exámenes separados de web, Linux, Windows y AD.
- Caso final integrador con rúbrica de metodología, precisión, evidencia, impacto y mitigación.
- Solucionarios separados; se consultan después de entregar el intento.

Criterios para avanzar

El estudiante avanza cuando puede:

- obtener al menos 70 % en el bloque;
- explicar por qué su prueba demuestra o no demuestra la hipótesis;
- identificar un falso positivo incluido deliberadamente;
- reconstruir el payload sin copiar una cadena completa;
- proponer una mitigación que elimine la causa, no solo un carácter;
- documentar la evidencia sin incluir secretos innecesarios.

Uso conjunto con la aplicación

El curso enseña mecanismos y razonamiento. THM Fieldbook aporta consulta rápida, comandos y metadatos durante la práctica. Cuando exista diferencia, el módulo explica el concepto y enlaza la fuente interna; la aplicación permanece como playbook operativo.

Cobertura y carencias

Los módulos se adaptarán a la cobertura real registrada en [_meta/mapa_fuentes.md](#). CSRF, RFI, deserialización insegura, request smuggling/desync, WebSocket smuggling, race conditions, prototype pollution, NoSQLi, systemd y Golden/Silver Tickets no se consideran actualmente cubiertos por la aplicación. Podrán añadirse después como ampliaciones externas claramente marcadas, no como contenido original.

Orden de lectura

1. 01_fundamentos/
2. 02_metodologia/
3. 03_seguridad_web/
4. 04_linux/
5. 05_windows/
6. 06_active_directory/
7. 07_redes_y_pivoting/
8. 08_ejercicios/
9. 09_exámenes/
10. 10_solucionarios/
11. 11_chuletas/